

Basic Artifacts of the MARISMA-IoT Pattern

Table 1. Asset Families and Types

Asset Family	Asset Type	Description
IoT Devices	Hardware	The different physical components (except sensors and actuators) from which the IoT devices can be built. These include microcontrollers, microprocessors, the physical ports of the device, the motherboard, etc.
IoT Devices	Software	Software comprises the IoT device's OS, its firmware and the programs and applications installed/running.
IoT Devices	Sensors	These are the subsystems whose purpose is to detect and/or measure events in its environment and send the information to other electronics in order to be processed. There are sensors for a lot of purposes, such as to measure temperature, motion, etc.
IoT Devices	Actuators	These are IoT device's output units, which execute decisions based on previously processed information.
IoT Devices	Sensors/Actuators (Added)	These IoT device's that can detect and/or measure events in its environment and execute decisions.
Other IoT Ecosystem Devices	Devices to interface with Things	These are devices whose purpose is to serve as an interface or as an aggregator between other IoT devices of a given IoT ecosystem. Moreover, devices used by users to interface and interact with IoT devices.
Other IoT Ecosystem Devices	Devices to manage Things	These are devices specially designed to manage other IoT devices, networks etc.
Other IoT Ecosystem Devices	Embedded systems	They are based on a processing unit that enables them to process data on their own. They include embedded sensors and/or actuators, network capabilities to connect directly to the cloud, a memory footprint and the ability to run software.
Communications	Networks	They allow the different nodes of an IoT ecosystem to exchange data and information with each other, via a data link. There are different kinds of networks according to their spatial coverage, which include (W)LANs, (W)PANs, PANs and (W)WANs, among others.
Communications	Protocols	They define the set of rules on how communication between two or more IoT devices must be performed through a given channel. There are many communication protocols, which can be either wireless or wireline-based. Examples of IoT communication protocols are ZigBee, MQTT, CoAP, BLE, etc.
Infrastructure	Routers	They are the networking components that forward data packets between the different networks of the IoT ecosystem.
Infrastructure	Gateways	These are the network nodes used for interfacing with another network from the IoT environment that uses different protocols. Gateways may provide protocol translators, fault isolators, etc., to provide system interoperability.
Infrastructure	Power supply	It supplies electric power to an IoT device and to its internal components. The power source can be external and wired or a battery integrated in the device itself.
Infrastructure	Security assets	This group comprises the assets specifically focused on the security of the IoT devices, networks and information. Most prominently, these include firewalls, Web Application Firewalls (WAF), CASBs for protecting the cloud, IDSs, IPSs and authentication/authorisation systems.
Platform & Backend	Web-based services	These are services within the World Wide Web, which provide a web-based interface to web users or to web-connected applications. This means web technologies can be used in IoT for Human-to-Machine (H2M) communications and for M2M communications.
Platform & Backend	Cloud infrastructure and services	In IoT, the cloud backend can be used to aggregate and process data from dispersed devices, and it also provides computing capabilities, storage, applications, services, etc.
Decision Making	Data mining	This refers to algorithms and services to process collected data and transform it into a defined structure for further use, using big data technologies for discovering patterns in very large data sets.
Decision Making	Data processing and computing	Services facilitating the processing of gathered data in order to obtain useful information, which can be used to apply rules and logic, to make decisions and to automate processes. Machine learning can be employed to learn from the use of information available over time.
Applications & Services	Data analytics and visualisation	Once the data has been collected and processed, the resulting information can be analysed and visualised in order to identify new patterns, improve operational efficiency, etc.
Applications & Services	Device and network management	The management of the IoT ecosystem devices and networks includes the software updates of the OS, firmware and applications. It also encompasses the tracking and monitoring of the devices and networks, collecting and storing logs that can later be used for diagnostics.
Applications & Services	Device usage	The contextualisation of the IoT ecosystem devices and networks, so as to understand the current status, usage patterns, performance, etc.

Table 1. Asset Families and Types

Asset Family	Asset Type	Description
Information	At rest	Information stored in a database in the cloud backend or in the devices themselves.
Information	In transit	Information sent or exchanged through the network between two or more IoT elements.
Information	In use	Information used by an application, service or IoT element in general.
Audio/Visual	Digital Streaming Output Systems	A set of electronic devices designed for the playback, storage, management, and streaming of multimedia content (audio, video, and images). These devices may include smart displays, media players, and sound systems.

Table 2. Threat Families and Types

Threat Family	Code	Threat Type	Description
Nefarious activity / Abuse	MI-NA01	Malware	Software programs designed to carry out unwanted and unauthorised actions on a system without the consent of the user, resulting in damage, corruption or information theft. Its impact can be high.
Nefarious activity / Abuse	MI-NA02	Exploit Kits	Code designed to take advantage of a vulnerability in order to gain access to a system. This threat is difficult to detect and in IoT environments its impact ranges from high to crucial, depending on the assets affected.
Nefarious activity / Abuse	MI-NA03	Targeted attacks	Attacks designed for a specific target, launched over a long period of time, and carried out in multiple stages. The main objective is to remain hidden and to obtain as much sensitive data/information or control as possible. While the impact of this threat is medium, detecting them is usually very difficult and takes a long time.
Nefarious activity / Abuse	MI-NA04	DDoS	Multiple systems attack a single target in order to saturate it and make it crash. This can be done by making many connections, flooding a communication channel or replaying the same communications over and over.
Nefarious activity / Abuse	MI-NA05	Counterfeit by malicious devices	This threat is difficult to discover, since a counterfeit device cannot be easily distinguished from the original. These devices usually have backdoors and can be used to conduct attacks on other ICT systems in the environment.
Nefarious activity / Abuse	MI-NA06	Attacks on privacy	This threat affects both the privacy of the user and the exposure of network elements to unauthorised personnel.
Nefarious activity / Abuse	MI-NA07	Modification of information	In this case, the objective is not to damage the devices, but to manipulate the information in order to cause chaos, or acquire monetary gains.
Eavesdropping / Interception / Hijacking	TH15	Replay attack / man-in-the-middle attack	Active eavesdropping attack, in which the attacker relays messages from one victim to another, in order to make them believe that they are talking directly to each other. This attack uses a valid data transmission maliciously by repeatedly sending it or delaying it, in order to manipulate or crash the targeted device.
Eavesdropping / Interception / Hijacking	MI-EI01	IoT communication protocol hijacking	Taking control of an existing communication session between two elements of the network. The intruder is able to sniff sensible information, including passwords. The hijacking can use aggressive techniques like forcing disconnection or denial of service.
Eavesdropping / Interception / Hijacking	TH05	Interception of information / eavesdropping	Unauthorised interception (and sometimes modification) of a private communication, such as phone calls, instant messages, e-mail communications.
Eavesdropping / Interception / Hijacking	MI-EI02	Network reconnaissance / information gathering	Passively obtain internal information about the network: devices connected, protocol used, open ports, services in use, etc.
Eavesdropping / Interception / Hijacking	MI-EI03	Session hijacking	Stealing the data connection by acting as a legitimate host in order to steal, modify or delete transmitted data.
Outages	TI04	Network outage / telecommunications network failure	Interruption or failure in the network supply, either intentional or accidental. Depending on the network segment affected, and on the time required to recover, the importance of this threat ranges from high to critical.
Outages	TT01	Failure of device or system	Threat of failure or malfunction of hardware devices. Threat of failure of software services or applications.
Outages	MI-OU01	Loss of support services	Unavailability of support services required for proper operation of the information system.
Damage / Loss (IT Assets)	TH10	Data / sensitive information leakage / disclosure	Sensitive data is revealed, intentionally or not, to unauthorised parties. The importance of this threat can vary greatly, depending on the kind of data leaked.
Failures / Malfunctions	MI-FM01	Software vulnerabilities	The most common IoT devices are often vulnerable due to weak/default passwords, software bugs, and configuration errors, posing a risk to the network. This threat is usually connected to others, like exploit kits, and it is considered crucial.
Failures / Malfunctions	MI-FM02	Third parties failures	Errors on an active element of the network caused by the misconfiguration of another element that has direct relation with it.
Disaster	MI-DI01	Natural Disaster	These include events such as, floods, heavy winds, heavy snows, landslides, among others natural disaster, which could physically damage the devices.
Disaster	MI-DI02	Environmental Disaster	Disasters in the deployment environments of IoT equipment and causing their imperability.
Physical attacks	TH12	Device modification / hardware tampering	Tampering a device by for example taking advantage of bad configuration of ports, exploiting those left open.

Table 2. Threat Families and Types

Threat Family	Code	Threat Type	Description
Physical attacks	TH20	Device or media damage / destruction (sabotage)	Incidents such devices theft, bomb attacks, vandalism or sabotage could damage devices.
Legal	TO04	Violation of laws or regulations / breach of legislation	Non-compliance with applicable laws, regulations, or legal requirements that govern the operation, data processing, or security of IoT systems. This may result in legal penalties, fines, or operational restrictions.
Legal	MI-LE01	Judiciary decision / Court order	A legally binding directive issued by a court that requires specific actions to be taken by an organization, such as data disclosure, service shutdown, or compliance measures. Failure to comply may lead to legal consequences.
Legal	MI-LE02	No-IP company domains seizure	Legal action taken by companys or other authorities to seize or block domains managed by No-IP due to alleged abuse, fraud, or malicious activity. This can lead to service disruptions and loss of domain control for legitimate users.
Legal	MI-LE03	Failure to meet contractual requirements	Inability to comply with contractual obligations agreed upon with partners, customers, or service providers, leading to potential legal disputes, financial penalties, or termination of agreements.
Physical threats	TP01	Fire	Combustion or uncontrolled fire that can damage or destroy devices, cabling, rooms, or other information-system infrastructure and interrupt services.
Physical threats	TP02	Water	Water intrusion, leakage, flooding, or other liquid exposure that can damage equipment, cause short circuits, or make facilities unavailable.
Physical threats	TP03	Pollution, harmful radiation	Exposure to contaminants or harmful radiation that can degrade equipment, interfere with operation, or create unsafe operating conditions.
Physical threats	TP04	Major accident	A serious accident affecting the building or surrounding infrastructure that can damage systems, disrupt services, or make facilities inaccessible.
Physical threats	TP05	Explosion	An explosive event that can physically damage equipment and facilities and cause loss of availability.
Physical threats	TP06	Dust, corrosion, freezing	Environmental conditions such as dust accumulation, corrosion, or freezing that can progressively degrade components and cause malfunction or failure.
Natural threats	TN01	Climatic phenomenon	Large-scale climatic conditions or events that can affect the physical environment, infrastructure, and continuity of IoT services.
Natural threats	TN02	Seismic phenomenon	Earthquakes or related ground movement that can damage buildings, devices, cabling, power, and communications.
Natural threats	TN03	Volcanic phenomenon	Volcanic activity, ash, gases, or related effects that can damage equipment, contaminate facilities, or interrupt services.
Natural threats	TN04	Meteorological phenomenon	Weather events such as storms, lightning, heavy rain, hail, strong winds, or extreme temperatures that can damage or disrupt systems.
Natural threats	TN05	Flood	Inundation of facilities or equipment by water, potentially causing physical damage, short circuits, and service outages.
Natural threats	TN06	Pandemic/epidemic phenomenon	A widespread disease outbreak that can reduce personnel availability, restrict site access, and impair normal operation and maintenance.
Infrastructure failures	TI01	Failure of a supply system	Failure of an external or internal utility or supply system required for operation, leading to degradation or interruption of dependent services.
Infrastructure failures	TI02	Failure of cooling or ventilation system	Failure of cooling or ventilation that can lead to overheating, unsuitable environmental conditions, equipment failure, or service interruption.
Infrastructure failures	TI03	Loss of power supply	Interruption or instability of electrical power that prevents devices, network elements, or support systems from operating normally.
Infrastructure failures	TI05	Failure of telecommunication equipment	Failure or malfunction of communications equipment such as routers, switches, gateways, access points, or modems, disrupting connectivity.
Infrastructure failures	TI06	Electromagnetic radiation	Electromagnetic emissions or interference that can disturb electronic equipment, communications, or sensor measurements.
Infrastructure failures	TI07	Thermal radiation	Exposure to excessive heat or thermal radiation that can degrade or damage equipment and affect safe operation.
Infrastructure failures	TI07	Electromagnetic pulses	Short, high-energy electromagnetic disturbances that can disrupt, damage, or disable electronic devices and communications.
Technical failures	TT02	Saturation of the information system	Exhaustion of processing, memory, storage, bandwidth, or other system resources, causing severe degradation or loss of service.
Technical failures	TT03	Violation of information system maintainability	Conditions that prevent or hinder effective maintenance, repair, updating, or restoration of the information system, increasing outage duration and residual risk.

Table 2. Threat Families and Types

Threat Family	Code	Threat Type	Description
Human actions	TH01	Terror. attack, sabotage	Deliberate destructive action intended to damage facilities, systems, or services, cause disruption, or compromise security.
Human actions	TH02	Social Engineering	Manipulation or deception of people to obtain information, credentials, access, or actions that bypass technical security controls.
Human actions	TH03	Interception of radiation of a device	Capture of electromagnetic or other emissions produced by a device to infer or obtain information without authorization.
Human actions	TH04	Remote spying	Unauthorized remote observation or monitoring of systems, communications, or users to collect sensitive information.
Human actions	TH06	Theft of media or documents	Unauthorized removal of physical or digital media or documents containing sensitive, operational, or security-relevant information.
Human actions	TH07	Theft of equipment	Unauthorized removal of devices or equipment, causing loss of assets and potentially exposing stored data, credentials, or configurations.
Human actions	TH08	Theft of digital identity or credentials	Theft or acquisition of usernames, passwords, tokens, certificates, keys, or other credentials used to impersonate legitimate users or devices.
Human actions	TH09	Retrieval of recycled or discarded media	Recovery of residual data from media or equipment that has been discarded, recycled, or reused without adequate sanitization.
Human actions	TH11	Data input from untrustworthy sources	Introduction of data from sources whose authenticity, integrity, or reliability has not been established, potentially leading to incorrect decisions or malicious effects.
Human actions	TH13	Tampering with software	Unauthorized modification of software, firmware, code, or configuration to alter behavior, introduce malicious functionality, or bypass controls.
Human actions	TH14	Drive-by-exploits using web- based communication	Compromise triggered when a user or device accesses malicious or compromised web content that exploits vulnerabilities through web-based communication.
Human actions	TH16	Unauthorized processing of personal data	Collection, use, alteration, disclosure, retention, or other processing of personal data without appropriate authorization or legal basis.
Human actions	TH17	Unauthorized entry to facilities	Physical access to buildings, rooms, cabinets, or restricted areas by persons without permission.
Human actions	TH18	Unauthorized use of devices	Use of devices, systems, or functions by persons or processes that do not have permission to do so.
Human actions	TH19	Incorrect use of devices	Improper or unintended operation of devices, whether accidental or deliberate, that can create errors, damage, or security exposure.
Human actions	TH21	Fraudulent copying of software	Unauthorized reproduction of software, potentially violating licensing or intellectual-property requirements and enabling uncontrolled distribution.
Human actions	TH22	Use of counterfeit or copied software	Use of unauthorized, counterfeit, or untrusted software copies that may be altered, unsupported, or unsafe.
Human actions	TH23	Corruption of data	Deliberate alteration or destruction of data so that it becomes inaccurate, inconsistent, unusable, or misleading.
Human actions	TH24	Illegal processing of data	Processing of data in a manner that violates applicable laws, regulations, contractual requirements, or established legal restrictions.
Human actions	TH25	Sending or distributing of malware	Introduction, transmission, or dissemination of malicious software intended to compromise devices, systems, data, or services.
Human actions	TH26	Position detection	Unauthorized determination or tracking of the physical location of a person, device, or asset through system or communication data.
Compromise of functions or services	TC01	Error in use	Unintentional mistakes in the operation or configuration of systems and devices that can cause malfunction, exposure, or loss of service.
Compromise of functions or services	TC02	Abuse of rights or permissions	Use of legitimate privileges beyond their intended purpose or authorized scope to access, change, disclose, or disrupt information and services.
Compromise of functions or services	TC03	Forging of rights or permissions	Falsification or manipulation of permissions, roles, credentials, or authorization data to obtain privileges not legitimately granted.
Compromise of functions or services	TC04	Denial of actions	Repudiation of actions by a user or system when evidence and accountability mechanisms are insufficient to demonstrate that the actions occurred.
Organizational threats	TO01	Lack of staff	Insufficient personnel capacity or availability to operate, monitor, maintain, secure, or recover systems effectively.

Table 2. Threat Families and Types

Threat Family	Code	Threat Type	Description
Organizational threats	TO02	Lack of resources	Insufficient financial, technical, physical, or operational resources to implement and sustain required security and service capabilities.
Organizational threats	TO03	Failure of service providers	Failure, interruption, or inadequate performance of an external service provider on which the organization or IoT ecosystem depends.

Note: Codes prefixed MI- are internal MARISMA-IoT consolidation identifiers assigned to ENISA-derived threat entries for which the source table provides no native code. ISO taxonomy codes are preserved as given in the source.

Table 3. Domains

Domain	Control / Common Elements	Explanation / Applicability to IoT Devices
NIST-derived cybersecurity domains		
Asset Management	Device integration and interoperability; lifecycle management; coordination of security policies in the IoT environment; documentation of device characteristics and lifecycle; information on device maintenance and support; notification of updates and support changes.	Covers overall supervision of device deployment, connection and decommissioning, ensuring that security is managed consistently throughout the ecosystem, including secure onboarding and retirement of assets.
Identity and Access Management (IAM)	Unique physical and logical identifiers; authentication and authorization; interface access control, including enabling or disabling ports and protocols; documentation of authentication and access management.	Ensures that only authorized entities and processes can interact with devices, using robust identification and authentication controls to restrict access to critical functions and resources.
Configuration and Change Management	Configuration policies; mechanisms for restoration to secure states; controls over parameter modification and access restrictions for changes.	Maintains device configuration in a secure state throughout its operational life, prevents unauthorized changes and supports recovery to predefined configurations after alterations.
Data Protection	Encryption of data at rest and in transit; integrity and confidentiality controls; cryptographic key management.	Protects information handled by the device against unauthorized access or modification by applying cryptographic techniques and policies that preserve the integrity and privacy of stored and transmitted data.
Vulnerability Management	Secure update mechanisms; authentication of update sources; patching and integrity verification during updates; channels for vulnerability reports; notification of vulnerabilities and available mitigations; information on maintenance and security updates.	Keeps devices resilient against emerging vulnerabilities by ensuring that updates and patches are applied securely and authentically, reducing risks from outdated or compromised software and ensuring that customers receive critical information about security flaws and required corrections.
Incident Detection and Response	Event logging and monitoring; log analysis; alerting and automated response mechanisms; consultation channels for security problems; incident notification and recommended responses; information on security-event management in devices.	Supports early identification of anomalies or security incidents through systematic event collection and analysis, enabling rapid and effective response. It also gives customers mechanisms to report and manage incidents and uses relevant information about failures and solutions to strengthen response and operational continuity.
Information Security Awareness, Education and Training	Education on secure configuration and data management; explanation of user security responsibilities; training on updates and device reprovisioning; training on device security functions; information on configuration and shared security responsibilities.	Improves users' ability to manage IoT-device security through training in good practices, secure configuration and appropriate disposal or reuse processes.
ISO/IEC 27001:2023 domains and controls		
Organizational	5.1 Policies for information security	Home owner: an informal but informed IoT security policy is recommended. Company: a formal policy should be approved, communicated, maintained and updated to ensure the protection and management of IoT devices on its premises.
Organizational	5.2 Information security roles and responsibilities	Home owner: roles and responsibilities may be assigned informally, but they should be clear and normally fall to the owner or another household member. Company: formal and specific management and operational roles are required so that IoT security is properly managed and audited.
Organizational	5.3 Segregation of duties	Home owner: duties can be shared among household members to avoid concentrating all device management in one person. Company: segregation of duties should be formal and structured so that no individual has complete, unsupervised access to critical IoT-related areas.
Organizational	5.4 Management responsibilities	Home owner: there is no formal management function, but the owner is responsible for following sound security practices and ensuring that they are implemented correctly. Company: management should ensure that all organizational levels follow the established IoT security policies and procedures, supported by training, audits and continuous compliance.
Organizational	5.5 Contact with authorities	Home owner: contact with authorities is less formal, but access to technical support, data-protection agencies and local authorities is important when a security incident occurs. Company: contact with authorities should be formalized, with clear incident-notification procedures, regulatory compliance and communication channels with regulatory and cybersecurity bodies.
Organizational	5.6 Contact with special interest groups	Home owner: participation in specialist groups is optional, although online IoT and cybersecurity communities can help users stay informed about good practices and vulnerabilities. Company: engagement with professional associations and industry groups is important for tracking emerging threats, good practices and applicable requirements.

Table 3. Domains

Domain	Control / Common Elements	Explanation / Applicability to IoT Devices
Organizational	5.7 Threat intelligence	Home owner: threat intelligence is based on using trusted information sources, keeping devices updated and applying secure configurations. Company: a structured approach should use threat-intelligence sources, active IoT monitoring, vulnerability analysis and information sharing with the cybersecurity community.
Organizational	5.8 Information security in project management	Home owner: Smart Home projects should assess security before installing devices, configure them correctly and keep them updated. Company: security should be formally integrated into IoT project management from risk assessment through implementation and continuous monitoring, while ensuring compliance with requirements and good practices.
Organizational	5.9 Inventory of information and other associated assets	Home owner: a basic inventory of IoT devices and their access paths helps reduce vulnerabilities and improve Smart Home security. Company: a formal IoT asset inventory is fundamental for risk management, access control and security compliance.
Organizational	5.10 Acceptable use of information and other associated assets	Home owner: basic rules should define who may access IoT devices and how personal data is protected. Company: an acceptable-use policy for IoT devices should be documented and should address access control, data protection and security compliance.
Organizational	5.11 Return of assets	Home owner: access should be removed when a person no longer needs control of IoT devices, for example by changing passwords or deleting accounts. Company: a formal process should recover IoT assets and revoke access when an employee or supplier leaves the organization.
Organizational	5.12 Classification of information	Home owner: the data generated by IoT devices should be identified and personal or sensitive information should receive additional protection. Company: a formal information-classification policy should ensure that IoT data is handled and protected according to its sensitivity.
Organizational	5.13 Labelling of information	Home owner: although a formal labelling scheme is generally unnecessary, sensitive data should still be identified and protected appropriately. Company: a data-labelling scheme should be aligned with the information-classification model and security controls should reflect data sensitivity.
Organizational	5.14 Information transfer	Home owner: IoT devices should transfer data using encryption and only to trusted destinations, with privacy permissions and settings reviewed. Company: information-transfer policies should include end-to-end encryption, third-party agreements and audits to protect IoT data.
Organizational	5.15 Access control	Home owner: IoT access should be protected with strong passwords, multi-factor authentication and network segmentation. Company: access control should be more sophisticated and may include biometric authentication, network segmentation, identity management and continuous monitoring.
Organizational	5.16 Identity management	Home owner: access to IoT devices should be actively managed, unnecessary access removed and strong authentication used. Company: identity management should be formalized through IAM, multi-factor authentication, role-based access control and continuous monitoring.
Organizational	5.17 Authentication information	Home owner: device credentials should be protected through strong passwords and multi-factor authentication where possible. Company: authentication information should be managed through a formal process that includes staff education on credential handling and multi-factor authentication for access to critical IoT systems.
Organizational	5.18 Access rights	Home owner: access rights should be kept simple but secure, unnecessary permissions removed and rights reviewed periodically. Company: formal access-rights management should use role-based assignment, regular audits and systematic modification or removal of rights when operational or personnel changes occur.
Organizational	5.19 Information security in supplier relationships	Home owner: relationships with IoT suppliers should be managed by checking for regular security updates, privacy standards and appropriate access arrangements. Company: supplier security risks should be assessed formally, security clauses should be included in contracts and supplier access to IoT infrastructure should be controlled and monitored.
Organizational	5.20 Addressing information security within supplier agreements	Home owner: even where agreements are informal, supplier terms of service should be reviewed for device security, data protection and remote-access safeguards. Company: supplier agreements should contain clear information-security clauses covering matters such as security audits, data protection and incident response, tailored to the supplier and its level of access.
Organizational	5.21 Managing information security in the ICT supply chain	Home owner: IoT products should be obtained from trusted suppliers that provide security assurances, regular updates and protection of personal information. Company: ICT supply-chain security should be formalized through continuous supplier assessment, contractual security clauses and lifecycle risk management covering both hardware and software.
Organizational	5.22 Monitoring, review and change management of supplier services	Home owner: supplier security notices, firmware changes and security-policy changes should be monitored so that associated devices and services are not compromised. Company: monitoring and change management should be continuous and structured, including periodic audits, risk assessment for changes and incident-response planning, especially where critical IoT infrastructure or cloud services are affected.
Organizational	5.23 Information security for use of cloud services	Home owner: cloud providers should offer data encryption, strong authentication and privacy safeguards; access should be carefully managed and data securely deleted when the service is no longer used. Company: cloud services should be governed by rigorous security assessments, contractual security requirements, strict access management, risk management, periodic audits and incident-response plans.

Table 3. Domains

Domain	Control / Common Elements	Explanation / Applicability to IoT Devices
Organizational	5.24 Information security incident management planning and preparation	Home owner: a basic incident-management plan should cover issues such as password compromise, unauthorized access and network vulnerabilities, with clear household responsibilities. Company: planning and preparation should be formal and detailed, with dedicated response teams, predefined procedures, exercises and integration with other management processes; rapid response and post-incident analysis are important.
Organizational	5.25 Assessment and decision on information security events	Home owner: suspicious or unauthorized activity should be assessed quickly to determine whether it affects information security or IoT operation. Company: a formal process should classify and prioritize events, determine whether they constitute incidents and support immediate communication, impact assessment and forensic analysis.
Organizational	5.26 Response to information security incidents	Home owner: incident response should be simple, rapid and documented, with clear steps to contain damage and restore IoT devices to normal operation. Company: response should follow a formal process for detection, containment, eradication and recovery, supported by documented procedures, regular exercises, post-incident analysis and coordination among teams.
Organizational	5.27 Learning from information security incidents	Home owner: lessons from incidents should lead to safer configurations and better practices to prevent recurrence. Company: incident learning should be formalized through detailed analysis, updates to security controls and continuing staff training, thereby strengthening organizational resilience.
Organizational	5.28 Collection of evidence	Home owner: evidence collection is less formal but can include preserving logs, screenshots and compromised devices so that the event can be understood and future practices improved. Company: evidence collection should follow detailed procedures that preserve integrity, comply with legal requirements and maintain an appropriate chain of custody.
Organizational	5.29 Information security during disruption	Home owner: key devices such as security cameras should have backup power and important data such as recordings should remain securely stored during power or network interruptions. Company: security during disruption requires more comprehensive planning, including backup power, data backups, redundant systems and procedures that maintain access control and information protection under critical conditions.
Organizational	5.30 ICT readiness for business continuity	Home owner: ICT continuity can include backup power for key devices, redundant Internet connectivity and data backups so IoT services remain operational and secure during disruption. Company: ICT readiness should be comprehensive, including backup power, redundant networks, secure distributed storage, disaster-recovery planning and periodic testing so critical infrastructure and industrial IoT can withstand interruptions without compromising security or business operations.
Organizational	5.31 Legal, statutory, regulatory and contractual requirements	Home owner: relevant requirements mainly concern privacy and personal-data protection in domestic IoT use; owners should be aware of applicable local laws and supplier contractual conditions. Company: legal, statutory, regulatory and contractual requirements are broader and can include data-protection, cybersecurity and sector-specific obligations that must be met and reflected in IoT deployments.
Organizational	5.32 Intellectual property rights	Home owner: intellectual-property issues mainly concern the licences associated with purchased IoT products and, where unique custom automations are developed, possible protection of those solutions; applicability is partial. Company: intellectual-property protection is essential and includes software, patents, trade secrets and agreements with employees and suppliers to protect ownership and avoid infringement.
Organizational	5.33 Protection of records	Home owner: IoT records such as video recordings and device-activity logs should be protected against unauthorized access. Company: record protection is critical for sensitive operational information and should use measures such as encryption, access management and continuous auditing to preserve integrity and confidentiality.
Organizational	5.34 Privacy and protection of personally identifiable information (PII)	Home owner: IoT devices should comply with applicable privacy rules, personal information should not be used without consent and the owner should retain control over what data is shared and how it is stored. Company: PII protection requires stronger legal and regulatory controls, including data minimization, access audits, privacy-incident handling and assurance that external suppliers also comply with data-protection requirements.
Organizational	5.35 Independent review of information security	Home owner: an independent security review is optional but recommended and may involve basic audits or assistance from a security professional to verify that IoT devices are updated and protected. Company: independent review is essential and should include periodic audits, penetration testing and IoT security assessments performed by external auditors or specialized internal teams.
Organizational	5.36 Compliance with policies, rules and standards for information security	Home owner: compliance is simplified but still involves reviewing IoT security configurations, keeping devices updated and observing applicable local privacy rules. Company: compliance should be formalized through internal and external audits, reviews of security standards, continuing supplier assessment and assurance that personnel follow established security policies.
Organizational	5.37 Documented operating procedures	Home owner: operating procedures are generally informal and focus on secure configuration, updating and protection of personal-data privacy, but simple and accessible documentation is recommended. Company: documented operating procedures should be detailed and formal, covering information security, IoT-device management, personal-data protection, incident response and regulatory compliance, with regular review to keep them current.
People	6.1 Screening	Home owner: screening is limited and is mainly relevant when selecting service providers to install or maintain IoT devices; formal background checks are uncommon, but provider trustworthiness should be verified. Company: background screening should be formal and proportionate to the access an employee will receive, especially for roles involving IoT devices, security systems or critical information, and should comply with legal and ethical requirements.

Table 3. Domains

Domain	Control / Common Elements	Explanation / Applicability to IoT Devices
People	6.2 Terms and conditions of employment	Home owner: terms and conditions with service providers or technicians should address personal-information protection, IoT-device security, confidentiality and privacy responsibilities. Company: employment terms should formally define personnel responsibilities for information security, IoT-device handling and sensitive-data protection, including confidentiality obligations, security policies and incident-response procedures.
People	6.3 Information security awareness, education and training	Home owner: awareness should focus on basic practices such as proper password use, Wi-Fi protection and understanding the privacy impact of IoT devices; highly structured training is not required. Company: awareness, education and training should be an integral part of organizational culture, delivered formally and periodically and tailored to roles, from basic security through IoT security, data protection and incident handling.
People	6.4 Disciplinary process	Home owner: a formal disciplinary process is generally unnecessary, but contractors or service providers should have agreements that define consequences for failing to follow household security requirements, with legal action possible for serious violations. Company: the disciplinary process should be formal, documented, proportionate to the severity of violations, clearly communicated and periodically reviewed.
People	6.5 Responsibilities after termination or change of employment	Home owner: post-service responsibilities should be defined in contracts with external providers; remote access should be revoked when service ends and confidentiality obligations should continue where applicable. Company: responsibilities after termination or role change should be formalized in employment terms, system access should be removed immediately and confidentiality obligations should remain in force.
People	6.6 Confidentiality or non-disclosure agreements	Home owner: confidentiality agreements should focus on external providers or technicians who can access IoT devices or personal household information, include clauses protecting privacy and sensitive information, and be reviewed when services change. Company: confidentiality agreements should cover employees, suppliers and contractors with access to sensitive information or IoT data, be reviewed periodically and remain aligned with organizational security policies.
People	6.7 Remote working	Home owner: remote-working security is simpler and focuses on protecting the home network and devices when they are accessed remotely. Company: controls should be much more rigorous, particularly in Smart Offices and Smart Factories where IoT devices may support industrial processes or intelligent-building functions.
People	6.8 Information security event reporting	Home owner: security-event reporting should be simple and accessible, allowing rapid identification and reporting of suspicious IoT activity through mechanisms such as an app or web portal, with clear guidance on what to do when a threat is detected. Company: reporting should be formalized through defined channels, incident-management platforms, staff training and rapid response procedures, with event handling embedded in organizational security culture.
Infrastructure	7.1 Physical security perimeters	Home owner: a physical security perimeter mainly protects the home through cameras, smart locks and sensors, and areas containing IoT devices should be protected against unauthorized physical access. Company: the perimeter should be more detailed and structured, protecting premises and critical IoT devices through access-control systems, continuous monitoring and advanced physical-security measures.
Infrastructure	7.2 Physical entry	Home owner: physical-entry controls focus on smart locks and motion sensors so that only authorized people can access areas containing IoT devices. Company: entry controls should be more complex, with advanced access-control systems, continuous monitoring and access audits for sensitive areas containing critical IoT devices.
Infrastructure	7.3 Securing offices, rooms and facilities	Home owner: workspaces and IoT devices should be protected using measures such as smart locks and monitoring so that critical areas cannot be accessed without authorization. Company: offices, rooms and facilities require stronger access controls, continuous monitoring and strict physical-security procedures to protect both premises and IoT devices used in office or factory environments.
Infrastructure	7.4 Physical security monitoring	Home owner: physical-security monitoring can use cameras and motion sensors to supervise entrances and sensitive areas containing IoT devices, including remote monitoring for unauthorized access. Company: monitoring is more critical in high-risk areas such as data centres or industrial-IoT zones and should use advanced cameras, intrusion sensors and real-time monitoring.
Infrastructure	7.5 Protecting against physical and environmental threats	Home owner: protection should address fires, floods and power failures through emergency sensors and backup power so that the home infrastructure and IoT devices continue operating under adverse conditions. Company: protection should be more comprehensive, including energy redundancy, reinforced infrastructure, advanced environmental monitoring and resilience against both natural events and attacks or sabotage.
Infrastructure	7.6 Working in secure areas	Home owner: this is generally not a formal control, but where relevant, maintenance and management of critical Smart Home devices should be limited to authorized people using suitable access controls and activity monitoring. Company: secure areas require stricter procedures, such as biometric controls, access cards and continuous monitoring, so that only authorized personnel can access critical infrastructure and operational IoT devices.
Infrastructure	7.7 Clear desk and clear screen	Home owner: computers and smartphones should be protected from unauthorized access by locking screens, storing sensitive documents and passwords securely, and removing removable media when unnecessary. Company: clear-desk and clear-screen rules should include automatic screen locking, secure storage of information on encrypted devices and physical protection of removable media.
Infrastructure	7.8 Equipment siting and protection	Home owner: sensitive equipment such as routers and security cameras should be placed where it is protected from unauthorized access, accidental damage, disasters and electrical failures. Company: critical equipment should be located in restricted areas such as server rooms or laboratories, with access controls, advanced physical protection, backup power, disaster protection and continuous monitoring.

Table 3. Domains

Domain	Control / Common Elements	Explanation / Applicability to IoT Devices
Infrastructure	7.9 Security of assets off-premises	Home owner: portable and externally located devices connected to the Smart Home should be protected with encryption, passwords, remote monitoring and appropriate physical protection. Company: off-premises assets include portable and remote IoT equipment and should use device encryption, remote management and appropriate physical and cybersecurity controls, including in factories or industrial sites.
Infrastructure	7.10 Storage media	Home owner: storage media and cloud storage should protect personal information through encryption, backups and secure deletion when data or devices are no longer needed. Company: storage-media management should be formalized across physical and cloud storage, with encryption, backup and secure-deletion policies, and IoT devices should be included throughout the information lifecycle.
Infrastructure	7.11 Supporting utilities	Home owner: backup power, such as UPS units, is important for security systems, thermostats and other critical smart devices, and alternative power arrangements can help preserve Internet connectivity. Company: information-processing facilities should have backup power such as UPS units and generators, as well as redundant networks so that critical IoT devices remain operational during supply failures.
Infrastructure	7.12 Cabling security	Home owner: network and power cabling should receive physical protection, for example through conduits or shielding, and wireless backup may reduce the impact of interference or unauthorized access in some cases. Company: telecommunications cabling carrying sensitive information should use secure conduits, shielding and continuous monitoring to reduce interception and physical-damage risks.
Infrastructure	7.13 Equipment maintenance	Home owner: IoT equipment should be kept functional and secure through updates, cleaning, checks and proper access management, especially when equipment is replaced or retired. Company: IoT maintenance should follow a preventive plan, include periodic security audits and protect equipment both physically and logically so that availability, integrity and confidentiality are preserved over time.
Infrastructure	7.14 Secure disposal or re-use of equipment	Home owner: retired or reused IoT devices should undergo secure data erasure, access revocation and factory reset so that private data cannot be recovered. Company: secure disposal or re-use is critical and should use rigorous procedures for secure erasure or, where necessary, physical destruction of storage media before equipment is reused or discarded.
Technology	8.1 User endpoint devices	Home owner: endpoint devices that store or access personal information should use strong passwords, data encryption, regular software updates and, where possible, multi-factor authentication; unnecessary remote access should be disabled. Company: endpoint security should be governed by rigorous policies, mobile-device management, encryption and multi-factor authentication to protect corporate information on devices and in communications.
Technology	8.2 Privileged access rights	Home owner: family members and other users should receive access only to the Smart Home devices they need, protected by strong passwords and appropriate authentication. Company: privileged access should follow least privilege and role-based access control, with only authorized personnel able to reach critical systems and with regular auditing and review.
Technology	8.3 Information access restriction	Home owner: personal information in IoT devices, Wi-Fi access and associated applications should be restricted to authorized family members or trusted people, using strong passwords and multi-factor authentication where needed. Company: information access should follow least privilege and RBAC, with physical and logical controls ensuring that employees can access only the information and systems required for their work, supported by regular reviews and audits.
Technology	8.4 Access to source code	Home owner: source-code access is generally a minor concern, but where IoT devices are customized the code should be protected with strong credentials and access limited to users who need to modify it. Company: access to source code and development tools should be strictly role-based, with change auditing to protect intellectual property, code integrity and systems from unauthorized or malicious modification.
Technology	8.5 Secure authentication	Home owner: secure authentication should use multi-factor authentication, strong passwords and, where appropriate, biometric authentication, while avoiding unprotected networks. Company: authentication should be structured around mandatory MFA, centralized credential management, digital certificates, password rotation and continuous access monitoring.
Technology	8.6 Capacity management	Home owner: capacity management focuses on optimizing network, storage and energy resources used by IoT devices to avoid overload and wasted resources. Company: IT infrastructure, network traffic and energy consumption should be monitored so that capacity is sufficient for current operations and future growth.
Technology	8.7 Protection against malware	Home owner: protection against malicious code includes antivirus use where applicable, firmware updates and avoiding suspicious downloads. Company: protection should be more robust, combining advanced security software, network monitoring, access controls and staff training.
Technology	8.8 Management of technical vulnerabilities	Home owner: technical-vulnerability management includes updating firmware, replacing default passwords and monitoring the home network to reduce unauthorized access to IoT devices. Company: a structured process should scan, update and monitor systems to minimize risk and protect critical data and operations.
Technology	8.9 Configuration management	Home owner: configuration management focuses on securing IoT devices and home networks, removing unsafe settings and keeping devices updated. Company: configuration management should be structured and supported by documentation, automation and continuous monitoring to maintain system security and stability.
Technology	8.10 Information deletion	Home owner: before disposal, devices should be reset, overwritten or physically destroyed as appropriate so that personal information cannot be recovered by third parties. Company: information deletion should be controlled, documented and aligned with applicable requirements so that deleted data cannot be recovered and confidential information is not leaked.

Table 3. Domains

Domain	Control / Common Elements	Explanation / Applicability to IoT Devices
Technology	8.11 Data masking	Home owner: data masking can help protect identity and privacy when using IoT devices and intelligent assistants. Company: masking is important to prevent exposure of sensitive data, particularly in testing or analytics environments, and to support compliance requirements.
Technology	8.12 Data leakage prevention	Home owner: data-leakage prevention focuses on securing networks and IoT devices against unauthorized access and exposure of personal information. Company: DLP tools, encryption and access controls should be used to protect sensitive information from accidental or malicious leakage.
Technology	8.13 Information backup	Home owner: backups should protect personal data and IoT-device configurations, use encrypted storage and be periodically tested for restoration. Company: a robust backup and disaster-recovery strategy should ensure that critical data and systems can be restored after failures, attacks or unexpected incidents.
Technology	8.14 Redundancy of information processing facilities	Home owner: redundancy supports IoT continuity through backup power, alternative Internet connections and backups. Company: redundancy should reduce outages and data loss through high-availability strategies, data replication and backup power sources.
Technology	8.15 Logging	Home owner: event logs can help monitor IoT-device behaviour and quickly identify anomalies. Company: logs are essential for auditing security activity, detecting threats and meeting requirements, and should be adequately protected and analysed.
Technology	8.16 Monitoring activities	Home owner: monitoring should cover IoT-device and home-network behaviour to identify unauthorized access or anomalies. Company: systems, networks and IoT devices require continuous monitoring to identify intrusions, failures or vulnerabilities, supported by tools that alert on unusual activity.
Technology	8.17 Clock synchronization	Home owner: clock synchronization is useful for keeping Smart Home event logs consistent, although it is not considered essential. Company: synchronization is crucial for coherent event records, accurate auditing and incident management, and also supports security and regulatory requirements.
Technology	8.18 Use of privileged utility programs	Home owner: privileged utility programs should be controlled through strong passwords and regular updates to protect the home network and IoT devices. Company: their use should be tightly controlled with multi-factor authentication, auditing and least privilege so that only authorized personnel can manage sensitive utilities.
Technology	8.19 Installation of software on operational systems	Home owner: software should be installed only from trusted sources, devices should remain updated and unverified software should be avoided. Company: software installation on production systems should be formally controlled, preceded by testing and version-control processes, and restricted to authorized personnel so that vulnerabilities are not introduced into critical systems.
Technology	8.20 Networks security	Home owner: Smart Home network security includes strong Wi-Fi credentials, segmentation of IoT devices and regular updating of connected devices. Company: network security should use segmentation, firewalls, communication encryption and continuous traffic monitoring to protect critical infrastructure and information in industrial and smart-office systems.
Technology	8.21 Security of network services	Home owner: sensitive network devices and services should be identified and protected with strong passwords, communication encryption and monitoring for unusual activity. Company: critical network services should be identified, protected and monitored with tools such as firewalls and intrusion-detection systems, and service-level agreements should adequately cover security and availability requirements.
Technology	8.22 Segregation of networks	Home owner: critical devices such as cameras and thermostats should be separated from less-sensitive devices using measures such as guest networks and firewalls. Company: networks should be segmented by function or privilege level, with internal firewalls and monitoring of traffic between segments to identify security risks.
Technology	8.23 Web filtering	Home owner: web filtering can block malicious sites and protect IoT devices and household members through router content filters, parental controls and endpoint security tools. Company: web filtering should protect the corporate network from malicious content, restrict inappropriate access and be combined with traffic monitoring and staff education.
Technology	8.24 Use of cryptography	Home owner: cryptography should protect Wi-Fi, communications between IoT devices and credentials, with security updates maintaining the effectiveness of protection. Company: cryptography should protect sensitive data in transit and at rest, with effective key management, authentication and digital signatures to preserve confidentiality, integrity and authenticity.
Technology	8.25 Secure development life cycle	Home owner: secure development lifecycle considerations mainly involve selecting IoT devices and applications from manufacturers that follow secure-development practices, keeping products updated and using trusted applications. Company: the secure development lifecycle should be formal, integrate security at every development stage, use continuous testing and proactively manage updates; a DevSecOps approach is identified as appropriate.
Technology	8.26 Application security requirements	Home owner: application security means selecting IoT devices and applications that are secure, privacy-conscious and updated, preferably products aligned with recognized security standards. Company: security requirements should be specified, approved and validated during application development and acquisition, and new solutions should undergo a thorough security assessment before deployment.
Technology	8.27 Secure system architecture and engineering principles	Home owner: smart devices and domestic systems should be selected and configured according to secure-design principles such as encryption and authentication to protect privacy and information integrity. Company: secure architecture and engineering principles should be established and documented as a foundation for systems that resist threats and protect organizational infrastructure.

Table 3. Domains

Domain	Control / Common Elements	Explanation / Applicability to IoT Devices
Technology	8.28 Secure coding	Home owner: secure coding is addressed indirectly by selecting Smart Home applications and platforms built according to sound security practices, with encrypted communications and regular security updates. Company: secure coding should apply security practices and principles throughout development so applications and systems resist cyberattacks and protect sensitive information and devices.
Technology	8.29 Security testing in development and acceptance	Home owner: smart devices and control applications should have undergone appropriate security evaluation before use so that known vulnerabilities are addressed. Company: security testing should be continuous and rigorous throughout development and acceptance, ensuring that systems and connected devices, including IoT, are secure and resistant to attacks.
Technology	8.30 Outsourced development	Home owner: when third parties develop or maintain smart systems or devices, they should follow good security practices and be bound by strong confidentiality arrangements. Company: outsourced development should be rigorously controlled, monitored and audited so external providers follow organizational security standards and deliver systems that integrate securely with existing infrastructure.
Technology	8.31 Separation of development, test and production environments	Home owner: separation of development, test and production may be less formal, but test devices and applications should be kept apart from operational assets, with access control and safe testing practices. Company: development, test and production environments should be strictly separated, with controlled access, isolated testing and a formal process for promoting software between environments.
Technology	8.32 Change management	Home owner: changes to smart devices or configurations should be controlled, tested before implementation and recorded so that later problems can be traced. Company: change management should be formal and include planning, testing and validation in controlled environments, access and approval procedures, and rollback plans.
Technology	8.33 Test information	Home owner: any test data associated with smart devices should be handled cautiously, avoiding sensitive personal data where possible and protecting it appropriately. Company: test data should be carefully selected, protected through measures such as encryption, restricted to authorized users and securely deleted when no longer needed.
Technology	8.34 Protection of information systems during audit testing	Home owner: audits of smart devices should be carefully planned and coordinated, use controlled access and respect privacy safeguards. Company: audit testing should be meticulously planned and agreed with appropriate managers, protect sensitive data, restrict access to authorized people and protect production systems while minimizing evaluation risks.

Table 4. Dimensions

Dimension	Description
Privacy	IoT devices in smart buildings collect and transmit large volumes of data, including personal information such as camera images, occupancy patterns and access credentials. If these data are intercepted, inadequately protected or sold without consent, users' privacy can be compromised, exposing them to identity theft, unauthorized surveillance and other rights violations.
Safety	A compromised IoT device can cause direct physical harm to people who interact with it. Examples in the source include automated doors that can be manipulated to close suddenly, HVAC sensor manipulation that can create extreme temperatures, intentional failures in smart-elevator access or movement control, and incorrect activation or deactivation of emergency lighting and alarms. These threats can endanger building occupants and may result in injury or fatal accidents.
Reliability	Smart Buildings depend on the correct operation of IoT devices such as sensors, actuators and control systems. Failures caused by errors, cyberattacks or hardware faults can create a non-functional or dangerous environment and can affect critical activities such as power supply, climate control and emergency systems.
Resilience	Resilience is the ability of the IoT system to recover from failures or attacks without compromising its operation. A system with low resilience may become unusable after a denial-of-service attack, another cyberattack or a physical failure, resulting in prolonged disruption of building operations.
Integrity	Physical integrity concerns protection against physical alteration or damage to IoT devices, including sensor tampering, cable cuts and system sabotage; physical attacks can disable essential components. Logical integrity concerns trust in processed and transmitted data: manipulated sensor information, such as false temperatures or incorrect device states, can trigger incorrect system responses, for example disabling security alarms or activating equipment without justification.
Availability	Availability ensures that IoT devices and their services are operational when needed. A denial-of-service attack, network failure or cloud interruption can prevent Smart Building systems such as lighting, access control, video surveillance and HVAC from operating correctly, affecting user safety and comfort.
Legality	Legality concerns due compliance with applicable laws, rules and regulations governing the use of IoT devices in Smart Buildings. Because these devices collect, process and transmit large amounts of data, including sensitive personal data, they must comply with privacy and data-protection requirements such as the GDPR in the European Union or the CCPA in California. A legally compliant IoT environment should obtain informed consent before data collection, process data fairly and transparently for specified purposes with limits on use and retention, ensure that devices and associated services comply with local and international security, privacy and information-protection requirements, and provide organizations with a legal framework for handling cybersecurity incidents and protecting user information. Legality also includes compliance with occupational-safety rules and industrial standards related to physical infrastructure and IoT devices.
Accountability	Accountability is the obligation of organizations to be answerable for their actions, decisions and the impact of IoT devices in a Smart Building. Responsible parties such as IoT providers, system administrators and developers should be able to demonstrate that appropriate measures have been taken to ensure system security, privacy and operation. The source highlights clear lines of responsibility for IoT management, maintenance and security; audit and traceability mechanisms that record activities, configuration changes and data access; transparency and communication of security or privacy incidents to affected parties and relevant authorities; and compliance with legal responsibilities, including data-protection, occupational-safety and industrial requirements.